BCA309T: Cryptography & Network Security

ACADEMIC SOLUTIONS MANUAL

Assignment 6: Introduction to Network Security and Cryptography (BCA309T-AS07)

Q1 Network Security Definition and Fundamental Objectives (CIA+2A Framework)

Network Security consists of the physical policies, system configurations, and cryptographic controls designed to prevent, detect, and mitigate unauthorized access, exploitation, modification, or disruption of networks and transit data. Core objectives:

- **Confidentiality:** Restricting payload access exclusively to authorized endpoints (enforced via AES-GCM encryption).
- **Integrity:** Guaranteeing that packets cannot be modified, injected, or replayed undetected (enforced via HMAC-SHA256).
- **Availability:** Ensuring resilient uptime for services and routing channels (enforced via DDoS scrubbing, multi-homing).
- **Authentication:** Cryptographically validating endpoint identities before session negotiation (enforced via PKI X.509).
- **Authorization:** Restricting access to internal network zones using Access Control Lists (ACLs) and Least Privilege policies.

Q2 Network Security Threat Landscape & Preventive Measures

Attack Type	Mechanism & Real-World Example	Vulnerability Exploited	Preventive Countermeasure
Eavesdropping (Sniffing)	Capturing plaintext packets using Wireshark over untrusted LAN/Wi-Fi to harvest credentials.	Unencrypted transport protocols (HTTP, Telnet, unencrypted POP3).	End-to-end transport layer encryption: HTTPS, SSH, and IPsec VPNs.
Man-in-the-Middle (MitM)	Poisoning local ARP tables (ARP Spoofing) to route victim traffic through attacker machine.	Lack of origin authentication in Layer-2 ARP broadcast requests.	Dynamic ARP Inspection (DAI), 802.1X Network Access Control, mutual TLS.
Denial of Service (DDoS)	SYN flooding or DNS Amplification overloading web server memory and pipe bandwidth.	Stateless protocol operations and resource-heavy TCP state tables.	SYN cookies, border BGP Anycast routing, Cloudflare/Akamai scrubbing filters.
Replay Attack	Intercepting a valid encrypted authentication token and re-sending it to gain entry.	Missing freshness mechanisms (nonces or synchronized timestamps).	Sequence numbers in IPsec ESP, cryptographic timestamps in Kerberos tickets.

Q3 Legal and Ethical Considerations in Network Security

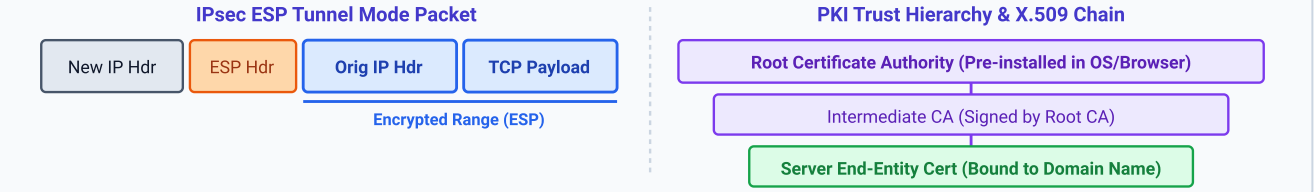
- **Authorized Access:** Penetration testing or port scanning against external subnets without prior written authorization is illegal under computer misuse legislation.
- **Responsible Security Testing (CVD):** Ethical security researchers adhere to *Coordinated Vulnerability Disclosure*—privately notifying vendors and providing a grace remediation window before public release.
- **Statutory Cybersecurity Laws:**
  - **IT Act, 2000 (India):** Section 43 penalizes unauthorized data extraction; Section 66 criminalizes computer-related hacking; Section 66F provides severe penalties for cyber-terrorism.
  - **DPDP Act, 2023 & GDPR:** Enforces Privacy by Design, mandatory breach notifications, and severe financial penalties for failing to encrypt personal customer data.

Q4 Role of Cryptography: SSL/TLS and IPsec Protocols

1. SSL/TLS (Transport Layer Security 1.3): Secures application-layer traffic over TCP (ports 443, 8443). The client sends supported ciphers and an ephemeral Diffie-Hellman (ECDHE) key share. The server responds with its selected cipher, its DH share, and an X.509 certificate. Both sides derive symmetric keys (AES-GCM) independently with Perfect Forward Secrecy (PFS).

2. IPsec (Network Layer Security): Transparently protects all Layer 3 IP traffic across two distinct modes:

- **Authentication Header (AH):** Protocol 51; guarantees packet integrity and origin authentication without encryption.
- **Encapsulating Security Payload (ESP):** Protocol 50; provides data confidentiality (AES), integrity, and anti-replay.
- **Transport Mode vs. Tunnel Mode:** Transport mode encrypts only the payload (host-to-host). Tunnel mode wraps the entire original packet inside a brand-new outer IP header (Site-to-Site VPNs).



Q5 Public Key Infrastructure (PKI), Digital Certificates & CAs

Public Key Infrastructure (PKI) is the comprehensive architecture of hardware, software, security policies, and legal controls managing public keys and digital certificates. Core components:

- **Certificate Authority (CA):** The trusted third party (e.g., DigiCert, Let's Encrypt) that signs and issues digital certificates after verifying ownership.
- **Registration Authority (RA):** Validates user and domain credentials before certificate issuance.
- **X.509 Digital Certificates:** Cryptographically binds an organization's identity to their public key, signed by a CA.
- **Revocation Infrastructures:** Manages compromised certificates via *Certificate Revocation Lists (CRL)* and the real-time *Online Certificate Status Protocol (OCSP)*.

Establishing Trust: Browsers trust servers because the server's certificate is cryptographically signed by an Intermediate CA, which in turn is signed by a Root CA embedded in the operating system's trust store, neutralizing MitM attacks.